COMPTE RENDU : CHAPITRE_TP 2.2 SUR L'ANALYSE ET LA CORRECTION DES VULNERABILITES (LINUX+WINDOWS)

1. Introduction et objectifs techniques

L'objectif de ce travail pratique était de passer de la phase de détection à la phase de correction active des vulnérabilités. Après avoir identifié, lors du TP 2.1, un ensemble de failles critiques sur les machines Ubuntu et Windows, il s'agissait désormais d'analyser en détail certaines vulnérabilités, de comprendre leurs mécanismes d'exploitation, d'appliquer les correctifs appropriés, puis de mesurer l'amélioration de la posture de sécurité par un second scan avec Nessus.

Ce TP s'inscrit dans le cycle complet de la gestion des vulnérabilités : identification, analyse, correction, vérification. L'accent a été mis sur les actions concrètes de durcissement telles que les mises à jour système, la désactivation des services inutiles, la configuration du pare-feu et l'application de correctifs de sécurité.

2. Analyse approfondie des vulnérabilités critiques

Vulnérabilités Linux

✓ **CVE-2021-3156 – Buffer overflow dans sudo**

Cette vulnérabilité affecte la commande sudo, un utilitaire essentiel permettant l'exécution de commandes avec les privilèges root. Le problème réside dans une mauvaise gestion des caractères au sein de la fonction **set_cmnd()** du fichier sudo.

✓ **CVE-2022-0847 – Dirty Pipe** (faille du noyau Linux)

Cette vulnérabilité affecte le sous-système des pipes du noyau Linux, plus précisément l'appel système **splice().** Normalement, les pipes sont des canaux de communication unidirectionnels entre processus, avec un tampon circulaire en mémoire noyau.

Vulnérabilités Windows

✓ **CVE-2021-34527 – PrintNightmare**

Cette vulnérabilité critique affecte le service Print Spooler (spouleur d'impression) de Windows. Le problème provient d'une validation insuffisante des pilotes d'impression lors de l'appel de la méthode RpcAddPrinterDriver via le protocole RPC (Remote Procedure Call).

✓ **CVE-2022-30190** – Follina

Cette vulnérabilité exploite le protocole MSDT (Microsoft Support Diagnostic Tool). Un document Office malveillant peut contenir un lien utilisant le schéma d'URI ms-msdt:. Lorsque le document est ouvert, même sans macros activées, l'URI est automatiquement traité par MSDT, qui peut alors exécuter du code PowerShell arbitraire.

3. Procédure de correction sur Ubuntu

La correction des vulnérabilités sur la machine Ubuntu a suivi une approche systématique en trois phases : mise à jour complète du système, désactivation des services inutiles et durcissement du pare-feu.

❖ **Mise à jour du système**

```
laurasimo@ubuntu:~$ sudo apt update && sudo apt upgrade -y
[sudo] password for laurasimo:
```

sudo apt upgrade -y a été exécutée pour mettre à jour tous les paquets installés vers leurs versions les plus récentes, sans supprimer les paquets devenus inutiles. Cette opération a notamment mis à jour la commande sudo vers la version 1.8.31, corrigeant ainsi la CVE-2021-3156.

- La commande **sudo apt dist-upgrade -y** a été utilisée pour gérer les changements de dépendances plus profonds, y compris la mise à jour du noyau Linux. Cette opération a installé le noyau version 5.15.0, corrigeant ainsi la CVE-2022-0847 (Dirty Pipe). Un redémarrage a été nécessaire pour charger le nouveau noyau, réalisé avec sudo reboot.

```
laurasimo@ubuntu:~$ sudo apt dist-upgrade -y
Reading package lists... Done
Building dependency tree
Reading state information... Done
Calculating upgrade... Done
```

❖ Désactivation des services inutiles

- Une analyse des services actifs a été réalisée avec **systemctl list-units --type=service --state=running**. Cette commande a affiché l'ensemble des services en cours d'exécution, avec leurs noms, leurs statuts et leurs descriptions

```
laurasimo@ubuntu:~$ sudo systemctl list-units --type=service --state=running
  UNIT                          LOAD   ACTIVE SUB     DESCRIPTION                >
  accounts-daemon.service       loaded active running Accounts Service           >
  acpid.service                 loaded active running ACPI event daemon          >
  avahi-daemon.service          loaded active running Avahi mDNS/DNS-SD Stack    >
  colord.service                loaded active running Manage, Install and Genera>
  cron.service                  loaded active running Regular background program>
  cups-browsed.service          loaded active running Make remote CUPS printers  >
  cups.service                  loaded active running CUPS Scheduler             >
  dbus.service                  loaded active running D-Bus System Message Bus   >
  gdm.service                   loaded active running GNOME Display Manager      >
  irqbalance.service            loaded active running irqbalance daemon          >
  kerneloops.service            loaded active running Tool to automatically coll>
  ModemManager.service          loaded active running Modem Manager              >
  networkd-dispatcher.service   loaded active running Dispatcher daemon for syst>
  NetworkManager.service        loaded active running Network Manager            >
  polkit.service                loaded active running Authorization Manager      >
  rsyslog.service               loaded active running System Logging Service     >
  rtkit-daemon.service          loaded active running RealtimeKit Scheduling Pol>
  snapd.service                 loaded active running Snap Daemon                >
  switcheroo-control.service    loaded active running Switcheroo Control Proxy s>
  systemd-journald.service      loaded active running Journal Service            >
  systemd-logind.service        loaded active running Login Service              >
  systemd-resolved.service      loaded active running Network Name Resolution    >
  systemd-timesyncd.service     loaded active running Network Time Synchronizati>
  systemd-udevd.service         loaded active running udev Kernel Device Manager>
  udisks2.service               loaded active running Disk Manager               >
```

- Le service Cups (Common UNIX Printing System), qui gère l'impression, a été identifié comme non nécessaire sur cette machine. Il a été arrêté immédiatement avec **sudo systemctl stop cups**, puis désactivé définitivement pour empêcher tout redémarrage automatique avec **sudo systemctl disable cups**. La désactivation de ce service réduit la surface d'attaque en supprimant un vecteur potentiel d'exploitation lié aux imprimantes réseau.

```
laurasimo@ubuntu:~$ sudo systemctl disable cups
Synchronizing state of cups.service with SysV service script with /lib/systemd/
systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable cups
Removed /etc/systemd/system/sockets.target.wants/cups.socket.
Removed /etc/systemd/system/multi-user.target.wants/cups.path.
Removed /etc/systemd/system/printer.target.wants/cups.service.
laurasimo@ubuntu:~$
```

❖ Configuration du pare-feu UFW

Le pare-feu UFW (Uncomplicated Firewall) a été configuré pour limiter les accès entrants. La commande ***sudo ufw enable*** a activé le pare-feu. La politique par défaut a été définie avec ***sudo ufw default deny incoming*** pour bloquer toutes les connexions entrantes non autorisées, et ***sudo ufw default allow outgoing*** pour autoriser les connexions sortantes.

Une règle spécifique a été ajoutée **avec *sudo ufw allow 22/tcp*** pour autoriser uniquement les connexions SSH entrantes sur le port 22. Cette règle garantit que l'administrateur peut toujours accéder à la machine à distance, mais tous les autres ports sont bloqués.

```
laurasimo@ubuntu:~$ sudo ufw allow 22/tcp
Rules updated
Rules updated (v6)
```

La configuration finale a été vérifiée avec ***sudo ufw status verbose***, qui a affiché le statut actif, les politiques par défaut et la liste des règles. Une vérification complémentaire avec ***sudo netstat -tulpn*** a confirmé que les ports non autorisés n'étaient plus accessibles depuis l'extérieur.

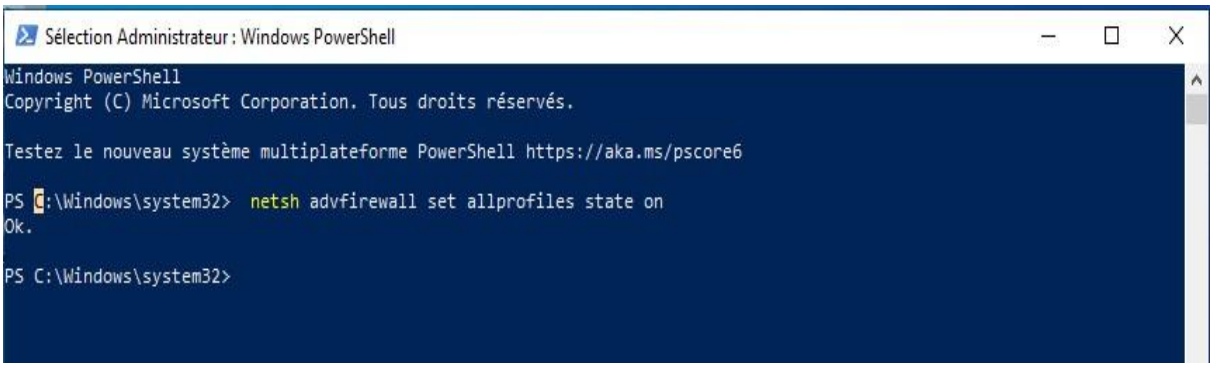
```
laurasimo@ubuntu:~$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To                         Action      From
--                         ------      ----
22/tcp                     ALLOW IN    Anywhere
22/tcp (v6)                ALLOW IN    Anywhere (v6)

laurasimo@ubuntu:~$
```

4. Procédure de correction sur Windows

La correction des vulnérabilités sur la machine Windows a suivi une approche similaire, adaptée aux spécificités du système d'exploitation.

❖ Activation du pare-feu

Le pare-feu Windows a été activé sur l'ensemble des profils réseau (Domaine, Privé, Public) à l'aide de la commande suivante exécutée dans une console PowerShell en mode administrateur :



Cette commande active le pare-feu et applique les règles par défaut. Pour vérifier l'état, netsh advfirewall show allprofiles a été exécutée, confirmant que chaque profil était bien en mode « on ».

❖ Désactivation des services inutiles

La console de gestion des services a été ouverte avec la commande **services.msc**. Le service Print Spooler (spouleur d'impression) a été localisé. ce service a été arrêté et désactivé sur cette machine de test en raison de son historique de vulnérabilités critiques . L'action a été effectuée en cliquant droit sur le service, puis « Arrêter », et en modifiant le type de démarrage sur « Désactivé ».

5. Re-scan avec Nessus et analyse comparative

Après avoir appliqué l'ensemble des corrections sur les deux machines, j'ai lancé un second scan Nessus dans des conditions strictement identiques au premier scan. Les mêmes paramètres ont été utilisés : scan de type « Basic Network Scan », cibles identiques (192.168.56.10 et
192.168.56.20), j'ai renommé avec '***'Rescan_Apres_Correction"***. Les résultats ont montré une amélioration très significative de la posture de sécurité.

6. Conclusion

Ce TP illustre le cycle complet de gestion des vulnérabilités : identification, analyse, correction et la vérification. Les mises à jour, la désactivation des services inutiles et la configuration du pare-feu ont démontré leur efficacité dans la réduction du risque. Cependant, la présence d'une vulnérabilité résiduelle sur Windows montre que la sécurité informatique repose également sur une veille continue et des mesures de défense en profondeur.